

[BEDRIJF] Regels voor informatiebeveiliging
Versie:
Datum:
Eigenaar:

Regels voor informatiebeveiliging

Dit template is gemaakt door de mensen van ICT Institute.

Het template mag gratis worden gebruikt, onder een creative commons licentie

<https://creativecommons.org/licenses/by/4.0/>

De nieuwste versie staat op:

<https://softwarezaken.nl/2022/01/gratis-27001-avg-templates/>

Je mag het template uitbreiden, aanpassen en bewerken zoveel je wilt

Je mag het template en documenten gemaakt met het template doorgeven en delen zoveel je wilt.

Als je het template doorgeeft, dan moet je "gemaakt door de mensen van ICT Institute" laten staan.

Als je een document maakt met dit template en je bent geen opdrachtgever van ons, zet dan "gemaakt met template van ICT Institute" ergens in het document

Als je een opdrachtgever bent van ICT Institute, dan mag je alles doen met dit template wat je wilt.

Let op dat je de ISO 27001 norm moet kopen bij NEN of een andere organisatie voordat je de norm gaat gebruiken. De norm is auteursrechtelijk beschermd.

Lees vooral ook deze artikelen als je aan de slag gaat:

<https://softwarezaken.nl/2017/03/samenvatting-iso-27001-informatie-beveiliging/>

<https://softwarezaken.nl/2021/12/iso-27001-certificatie-aanvraag/>

<https://softwarezaken.nl/2018/01/gdpr-avg-in-10-stappen/>

<https://softwarezaken.nl/security-verified/>

Achtergrond regels

Voor wie zijn deze regels?

Iedereen in onze organisatie met toegang tot informatie heeft een belangrijke rol bij het beveiligen van informatie. Het maakt niet uit of je in de IT, HR, Legal of in andere delen van het bedrijf werkt: de regels zijn van toepassing op **personeel** dat in of voor onze organisatie werkt. Dit zijn:

- Medewerkers in dienst;
- Stagiairs en tijdelijk personeel;
- Onafhankelijke professionals of leverancierspersoneel met toegang tot onze gebouwen of informatie.

Verplichting en disciplinaire maatregelen (A6.4)

Je zal een kopie van dit document ontvangen bij je arbeidscontract of op je eerste werkdag.

Door het tekenen van het contract ga je akkoord met deze regels, en vanaf dan moet je de regels volgen. De verplichting tot geheimhouding blijft bestaan ook na het ontvangen van de laatste vertrouwelijke informatie.

[BEDRIJF] Regels voor informatiebeveiliging
 Versie:
 Datum:
 Eigenaar:

Het niet naleven van deze regels zal leiden tot disciplinaire maatregelen zoals formele waarschuwingen, schorsing of zelfs ontslag. Meer details zijn verkrijgbaar bij HR.

Algemene verplichtingen voor informatiebeveiliging

Iedereen die in deze organisatie werkt, is verplicht om informatie veilig te houden.

- Je mag gevoelige informatie niet openbaar maken aan buitenstaanders of informatie publiceren, tenzij dit deel uitmaakt van je rol en de classificatie van de informatie dit toelaat;
- Je bent verplicht om alle regels voor informatiebeveiliging te kennen en te volgen;
- Je bent verplicht de nodige zorgvuldigheid in acht te nemen met alle gegevens, vooral met betrekking tot persoonlijke gegevens;
- Je bent verplicht de nodige zorgvuldigheid in acht te nemen met door [BEDRIJF] uitgegeven apparaten;
- Je bent verplicht om incidenten onmiddellijk te melden. Dit omvat bijvoorbeeld het verlies van een apparaat, een vermoeden van een hack of een onwerkbaar situatie.

Classificatie van informatie (A5.9)

Alle informatie die we gebruiken, valt in een bepaalde categorie van informatie. Hieronder zijn de categorieën weergegeven.

Categorie	Omschrijving	Voorbeelden
Zeer geheim	Persoonlijke wachtwoorden, cryptosleutels tot belangrijke websites	TLS-certificaten, persoonlijke wachtwoorden
Confidential/vertrouwelijk	Documenten van opdrachtgevers documenten met niet-openbare persoonsgegevens, documenten opgeslagen in projectfolders.	Projectplan,....
Intern gebruik	Informatie alleen bedoeld voor medewerkers	Templates, materiaal presentaties/trainingen, interne documenten
Openbaar	Gepubliceerde informatie	Website-artikelen of gepubliceerde informatie, open standaarden,

Bij eigen documenten is het streven om de categorie op de titelpagina of in de header aan te geven. Als er niets in aangegeven, moet je op basis van de plaats of context de categorie bepalen. Als dat niet lukt, beschouw het document dan als confidential/vertrouwelijk.

In de tabel hieronder staat hoe je met de informatie moet omgaan.

Categorie	Hoe opslaan	Met wie delen	Hoe versturen	Fysieke opslag
Zeer geheim	In folder alleen toegankelijk voor klein team	Alleen een klein team	Versleuteld met wachtwoord via apart kanaal. Niet per post/koerier	In afgesloten kast

[BEDRIJF] Regels voor informatiebeveiliging

Versie:

Datum:

Eigenaar:

			versturen, maar persoonlijk afgeven.	
Confidential/ vertrouwelijk	Alleen in beperkt toegankelijke plek .	Alleen delen met mensen die een rol hebben in het project of informatie nodig hebben	Aan externen via email, tenzij dit tegen beleid cliënt is. Liever niet per post/koerier versturen, maar persoonlijk afgeven.	In afgesloten kast
Intern gebruik	Opslaan in daarvoor bedoeld systeem.	Kan gedeeld worden met alle medewerkers.	Mag via email.	In kantoor
Openbaar	Opslaan in daarvoor bedoeld systeem	Kan vrij gedeeld worden. Tip: deel de link naar het artikel.	Mag via alle kanalen.	Geen beperkingen.

Aanvaardbaar gebruik informatie en andere gerelateerde bedrijfsmiddelen (A5.10)

Ga zorgvuldig om met alle laptop, telefoons en andere apparatuur. Vervangen of repareren is een heel gedoe. Pas op met water/ koffie, pas op met randen van tafels, gebruik een goede tas / rugzak voor vervoer en laat apparatuur niet onbeheerd achter. Leen apparatuur ook niet uit aan anderen, zonder goedkeuring vooraf van de IT-admin of CEO.

Beheer van wachtwoorden (A5.17)

Je bent verplicht om zorgvuldig met wachtwoorden om te gaan. Je moet de volgende regels volgen:

- Gebruik tweefactor-authenticatie (2FA of MFA) waar mogelijk.
- Als je een nieuw account met standaard of voor jou gekozen wachtwoord krijgt, wijzig dan het wachtwoord.
- Kies voor elke dienst een nieuw, niet te raden wachtwoord dat je niet eerder hebt gebruikt.
- Maak het wachtwoord minimaal 10 tekens lang en stop er hoofdletters, kleine letters en cijfers in. Bij gebruik pincode op een telefoon, kies dan 6 cijfers i.p.v. 4 als dat mogelijk is.
- Deel je persoonlijke wachtwoorden met niemand.
- Bewaar wachtwoorden op een veilige plek. Laat wachtwoorden (m.u.v. wachtwoord gasten-wifi-netwerk) nooit zichtbaar achter op bureaus etc.

Intellectueel eigendom (A5.32)

Op teksten en afbeeldingen rust auteursrecht, en we mogen niet alle teksten en afbeeldingen zomaar gebruiken. Het volgende mag:

[BEDRIJF] Regels voor informatiebeveiliging

Versie:

Datum:

Eigenaar:

- Je mag 1-2 zinnen per keer citeren met bronvermelding (naam document of URL). Hiervoor is geen toestemming nodig. Ook een screenshot van een website die je bespreekt is toegestaan.
- Je mag afbeeldingen gebruiken van Noun Project, Unsplash of Wikimedia Commons. Dit zijn zogeheten creative commons. Vermeld de naam van de maker op dezelfde pagina of achterin document. Andere afbeeldingen van Internet mag niet.
- Bij foto's waar personen herkenbaar op staan, heb je toestemming van de persoon nodig. Het makkelijkste is om geen foto's te gebruiken waar mensen herkenbaar opstaan.
- De ISO vindt het vervelend als hun logo gebruikt wordt, zelfs als je gecertificeerd bent. Gebruik het logo van ISO zelf niet.

Privacy en AVG (A5.34)

Als er persoonsgegevens in documenten staan, dat moet je er conform de AVG mee omgaan:

- Documenten en gegevens alleen gebruiken voor afgesproken doel. Dus gegevens voor review niet gebruiken voor sales en marketing.
- Incidenten en mogelijke datalekken moeten direct gemeld worden.
- Persoonsgegevens niet delen met subverwerkers tenzij zo afgesproken
- Persoonsgegevens na gebruik verwijderen.

Verantwoordelijkheden na beëindiging dienstverband (A6.5)

De verplichting tot geheimhouding blijft bestaan ook nadat je uit dienst gaat, we gaan proberen je hieraan te herinneren in een uitdienstgesprek. Als je uit dienst gaat moet je op de laatste actieve werkdag alle laptops en telefoons inleveren. Je moet ook alle vertrouwelijke informatie teruggeven of verwijderen.

Geheimhouding (A6.6)

Je werkt bij ons met niet-openbare informatie en je moet deze geheim houden. We verwachten concreet het volgende:

- Dat alle informatie ontvangen in het kader van een opdracht, of verstrekt voor het maken van een offerte, als geheim wordt beschouwd. De enige uitzonderingen zijn informatie die we al op andere wijze hadden ontvangen en informatie die al publiekelijk te vinden was.
- Dat alle geheime informatie alleen wordt gebruikt voor het doel waarvoor het is verstrekt en alleen verder wordt verspreid als dat nodig is voor dit doel.
- Dat iedereen zijn best doet om geheime informatie goed te beschermen, op minimaal hetzelfde niveau als de eigen bedrijfsinformatie.
- Geheimhouding blijft in principe drie jaar gelden, of langer als dat staat in de NDA of opdrachtvoorstel van het project.

Werken op afstand (A6.7)

Ja mag thuis werken of op derde locaties (restaurants, bij opdrachtgevers), zolang niemand met je scherm kan meelezen (shoulder surfing) of je gesprekken kan meeluisteren. (eavesdropping). Denk eraan je scherm te locken als je de laptop achterlaat.

[BEDRIJF] Regels voor informatiebeveiliging

Versie:

Datum:

Eigenaar:

Openbare netwerken of gastnetwerken mogen worden gebruikt als er geen andere netwerken beschikbaar zijn, zolang alleen met https beschermde websites worden bezocht. Houd er rekening mee dat het verkeer van onbeveiligde websites kan worden afgeluisterd. Als er geen betrouwbare netwerken beschikbaar zijn, maak dan gebruik van de hotspot op je telefoon.

Melden van Incidenten (A6.8)

Je bent verplicht om alle incidenten direct te melden

Een **(beveiligings-)incident** is een concrete gebeurtenis of een reeks gebeurtenissen waarbij de beschikbaarheid, vertrouwelijkheid en/of integriteit van een informatie-asset is geschonden.

Voorbeelden van incidenten die je moet melden zijn:

- Verkeerd verstuurde mail met vertrouwelijke informatie (NB: vraag ook direct de ontvanger om de mail te verwijderen)
- Verlies van laptop, telefoon of ander apparaat met informatie
- Uitvallen van laptop als je daardoor niet kunt werken
- Virus / malware op laptop
- Als je gereageerd hebt op een phishingmail of de bijlage geopend hebt

Phishing komt nog steeds veel voor. Controleer alle mails op afzender en check links voordat je klikt.

Ook zwakheden in onze systemen moet je melden, zodat ze kunnen worden opgelost.

Clean desk en clear screen (A7.7)

Als je een werkplek gebruikt, laat dan geen vertrouwelijk materiaal liggen. Bij het verlaten van de werkplek moeten alle documenten van de bureaus worden verwijderd en op een niet-zichtbare manier worden opgeslagen. Vertrouwelijke documenten moeten worden opgeslagen in vergrendelde lades of archiefkasten. Een computerscherm moet gelockt zijn als je weg bent.

Beveiliging user end-point devices (A8.1)

Als je een tablet, mobiele telefoon of een ander apparaat ontvangt, dien je dit apparaat met zorg te gebruiken om ervoor te zorgen dat de informatie op dit apparaat veilig is. Houd in ieder geval de volgende regels aan:

- Schakel beveiligingsfuncties op het apparaat niet uit;
- Deel het apparaat niet met andere mensen;
- Open geen verdachte e-mails;
- Installeer geen apps van onbekende oorsprong;
- Beveilig het apparaat met een veilig wachtwoord / pin en 2-factor authenticatie;
- Versleutel de opslag op apparaten;
- Scan laptops regelmatig op virussen / malware;

[BEDRIJF] Regels voor informatiebeveiliging

Versie:

Datum:

Eigenaar:

- Houd software up-to-date, in overeenstemming met de aanbevelingen van de fabrikant;
- Als een apparaat beschadigd lijkt te zijn, schakel je het apparaat uit en handig je het persoonlijk aan IT-personeel;
- Als een apparaat zoekraakt of wordt gestolen, meld dit dan onmiddellijk aan de Security Officer;
- Als je beveiligingsinstructies van IT-medewerkers van het bedrijf via een officiële e-mail ontvangt, volg deze instructies. Bij twijfels over de echtheid van zo'n soort mail, neem dan direct contact op met het InfoSec team.

Op laptops mag je naar eigen inzicht software installeren die je nodig hebt voor werk. Op laptops mogen geen games en recreatieve software worden geïnstalleerd, tenzij nodig voor een klantopdracht.

Plek voor handtekening	Naam: _____ Plaats, Datum: _____
------------------------	--